TARMOQ XAVFSIZLIGI

A17. Tarmoq xavfsizligi insidentlarini boshqarish

1-VARIANT — Ruxsatsiz HTTP murojaatini aniqlash va bartaraf etish

Mashg‘ulot maqsadi. Talaba tarmoqdagi shubhali hodisani log orqali aniqlaydi, insident sifatida baholaydi, uning ko‘lami va ta’sirini dalillar bilan asoslaydi. Manba kompyuterni vaqtincha ajratish, dalillar nusxasini saqlash, noto‘g‘ri konfiguratsiyani tuzatish, xizmatni qayta tekshirish va yakuniy hisobot tuzish bajariladi.

Senariy. Kafedra veb-serverida ichki foydalanish uchun mo‘ljallangan katalog tasodifan ochiq qolgan. USERS segmentidagi CLIENT ushbu katalogdagi belgilangan o‘quv faylini oladi. Administrator logdan murojaatni aniqlaydi, CLIENT trafikini cheklaydi va serverdagi ruxsat siyosatini tuzatadi. Ochiq bosh sahifa ishlashi saqlanishi kerak.

Ko‘rsatkich	1-variant sharti
Fan / semestr	Tarmoq xavfsizligi / faqat 5-semestr
Dasturdagi hajm	4 akademik soat; asosiy tajriba va chuqurlashtirish
Vaqt rejasi	Asosiy qism ≈80 daqiqa; tahlil/himoya ≈80 daqiqa
Kompyuter xonasi	30 ta Windows 11 host; 8 yadro, 32 GB RAM, SSD 1 TB
Tarmoq va vosita	LAN, Internet; VMware Workstation yoki VirtualBox
Virtual muhit	RTR-IR, WEB, CLIENT, ADMIN — Ubuntu Server 24.04 LTS
Vositalar	nginx, nftables, curl, OpenSSH, Python 3, sha256sum
Natija	Insident kartasi, dalil paketi, vaqt chizig‘i va 10 sinov

Ishning chegarasi va kutiladigan natija

Faylda faqat A17-DEMO-NOT-REAL-DATA yozuvi bo‘ladi. Haqiqiy shaxsiy ma’lumot, zararli dastur, parol buzish yoki tashqi manzilga trafik yuborish ishlatilmaydi. Insident maxsus o‘quv ruxsat siyosati buzilishini modellashtiradi; CLIENTga zararli dastur tushgani oldindan da’vo qilinmaydi.

- Hodisa — kuzatilgan amal; insident — xavfsizlik siyosati buzilgan yoki unga real tahdid tug‘ilgan vaziyat.
- Dalil — xulosani qo‘llab-quvvatlovchi log, konfiguratsiya, fayl yoki o‘lchov; taxmin alohida qayd etiladi.
- Cheklash (containment) — ta’sir yoyilishini vaqtincha to‘xtatish; sababni bartaraf etish esa serverdagi noto‘g‘ri ruxsatni tuzatadi.
- Tiklash — xizmatni belgilangan ruxsatlar bilan ishlatish va qayta nazorat qilish; yakunlashda o‘rganilgan saboqlar yoziladi.

NIST SP 800-61 Rev. 3 insidentlarga javob berishni CSF 2.0 asosidagi risk boshqaruvi bilan bog‘laydi. Ushbu ishda tayyorgarlik, aniqlash, javob va tiklash amallari bir senariyda o‘rgatiladi; bu tashkilotning to‘liq insident boshqaruvi tizimi emas. [1]

1. Laboratoriyani tayyorlash va rollar

VM	vCPU / RAM / disk	Lab adapterlari
RTR-IR	2 / 2 GB / 20 GB	A17-MGMT, A17-SRV, A17-USERS
WEB	2 / 2 GB / 20 GB	Faqat A17-SRV
CLIENT	1 / 2 GB / 20 GB	Faqat A17-USERS
ADMIN	2 / 2 GB / 20 GB	Faqat A17-MGMT

Har hostga jami 8 GB RAM va 80 GB virtual disk ajratiladi. Obraz importi va paketlar o‘rnatilishi darsdan oldin bajariladi. Har talaba mustaqil labda ishlaydi; juftlikda ishlansa bir talaba operator, ikkinchisi auditor bo‘lib, tiklash bosqichida rollar almashadi.

1.1. O‘qituvchining darsdan oldingi tayyorgarligi

1. Ubuntu VMlarini tayyorlang. WEB va RTR-IRda labadmin nomli sudo huquqli hisob bo‘lsin. Barcha VMlarda sanani tekshiring; tayyorgarlikda vaqtni sinxronlang.
2. Vaqtinchalik NAT adapter orqali paketlarni o‘rnating. Quyidagi buyruqlar Ubuntu Bash terminali uchun; Windows hostdagi PowerShellga yozilmaydi.
3. VirtualBoxda uchta Internal Network, VMwareda uchta LAN Segment yarating. Nomlari jadvaldagidek bo‘lsin; endpointlar bittadan, router uchala segmentga ulanadi.
4. Paketlar tayyor bo‘lgach barcha NAT kabellarini uzing yoki adapterlarni olib tashlang. Bridged va port forwarding ishlatilmaydi. Har VMdan A17-base snapshot oling.

```
# Har bir VMda:
sudo apt update
sudo apt install -y curl python3 nano openssh-client netcat-openbsd
# RTR-IRda:
sudo apt install -y nftables tcpdump openssh-server
# WEBda:
sudo apt install -y nginx openssh-server
# Yangi, ajratilgan WEB va RTR-IR obrazlarida:
sudo ufw disable
sudo systemctl enable --now ssh
```

1.2. Insident boshqaruvidagi rollar

Rol	Ushbu laboratoriyadagi mas’uliyat
Koordinator — o‘qituvchi	Insident darajasi va tiklash mezonini ko‘rib chiqadi.
Operator — talaba	VM, log, firewall va xizmat sozlamalarini bajaradi.
Auditor — sherik yoki o‘qituvchi	Dalil hashlarini, vaqtlarni va yopish mezonini tekshiradi.

30 hostdagi IP manzillar takrorlanishi mumkin, chunki virtual segmentlar alohida. Sinovlar xona LANi yoki Internetga chiqarilmaydi. O‘qituvchi tanlangan hypervisorda to‘liq tajribani oldindan tekshiradi. Kod shablonlari tayyor holda berilsa, asosiy qism 80 daqiqaga yaqin bajariladi.

2. Router va IP-manzillash

Obyekt	IPv4 / prefiks	Shlyuz
RTR-IR / MGMT	10.170.10.1/24	Yo‘q
RTR-IR / SRV	10.170.20.1/24	Yo‘q
RTR-IR / USERS	10.170.30.1/24	Yo‘q
ADMIN	10.170.10.10/24	10.170.10.1
WEB	10.170.20.10/24	10.170.20.1
CLIENT	10.170.30.10/24	10.170.30.1

Trafik yo‘li: CLIENT → USERS → RTR-IR → SRV → WEB. ADMIN MGMT segmentidan router va WEBni boshqaradi. WEB bilan CLIENT bir segmentda bo‘lmagani sabab ularning aloqa yo‘li router orqali o‘tadi; shu nuqtada manba ajratiladi.

2.1. RTR-IR root konsolida

ip -br link natijasini hypervisor adapter MAC manzillari bilan solishtiring. enp0s3/enp0s8/enp0s9 nomlarini o‘z interfeyslaringizga moslang; VMwareda ens33 kabi nomlar uchraydi.

```
sudo -i
ip -br link
MGMT_IF=enp0s3
SRV_IF=enp0s8
USERS_IF=enp0s9
for nic in "$MGMT_IF" "$SRV_IF" "$USERS_IF"; do
  ip link set "$nic" up
  ip -4 addr flush dev "$nic" scope global
done
ip addr add 10.170.10.1/24 dev "$MGMT_IF"
ip addr add 10.170.20.1/24 dev "$SRV_IF"
ip addr add 10.170.30.1/24 dev "$USERS_IF"
ip -4 route flush default
sysctl -w net.ipv4.ip_forward=1
mkdir -p /opt/a17/case-001
ip -br addr
ip -4 route
```

2.2. Har endpoint root konsolida — WEB misoli

```
sudo -i
LAB_IF=enp0s3
LAB_IP=10.170.20.10/24
LAB_GW=10.170.20.1
ip link set "$LAB_IF" up
ip -4 addr flush dev "$LAB_IF" scope global
ip addr add "$LAB_IP" dev "$LAB_IF"
ip route replace default via "$LAB_GW"
mkdir -p /opt/a17/case-001
ip -br addr
ip -4 route
date -Is
```

ADMIN va CLIENT uchun LAB_IP/LAB_GWni jadvalga moslang. Ushbu IP va forwarding sozlamalari vaqtinchalik: tajriba davomida VMlar qayta yuklanmaydi, segmentlarda DHCP ishlamaydi. Davom ettirish zarur bo‘lsa VM holatini saqlang; rebootdan keyin 2–3-bo‘limni qayta qo‘llash kerak bo‘ladi.

3. Asosiy firewall va boshqaruvga kirish

Quyidagi siyosat RTR-IRda yaratiladi. Interfeys nomlarini moslang. Bu faqat toza, ajratilgan o‘quv routeri: flush ruleset avvalgi nft qoidalarini almashtiradi. Boshqa xizmat yoki oldingi mashg‘ulot firewalli mavjud VMda bajarilmaydi. [2]

```
cat > /opt/a17/base.nft <<'EOF'
flush ruleset
table inet a17_base {
  chain input {
    type filter hook input priority 0; policy drop;
    iifname "lo" accept
    ct state established,related accept
    iifname "enp0s3" ip saddr 10.170.10.10 tcp dport 22 accept
    iifname "enp0s3" ip saddr 10.170.10.10 ip protocol icmp accept
  }
  chain forward {
    type filter hook forward priority 0; policy drop;
    ct state invalid drop
    ct state established,related accept
    iifname "enp0s3" oifname "enp0s8" ip saddr 10.170.10.10 \
      ip daddr 10.170.20.10 tcp dport { 22, 80 } counter accept
    iifname "enp0s9" oifname "enp0s8" ip saddr 10.170.30.10 \
      ip daddr 10.170.20.10 tcp dport 80 counter accept
    counter drop
  }
  chain output {
    type filter hook output priority 0; policy accept;
  }
}
EOF
nft -c -f /opt/a17/base.nft && nft -f /opt/a17/base.nft
nft list ruleset > /opt/a17/case-001/base-rules.txt
```

Hozir CLIENTga WEB:80 ruxsat etilgan, SSH va boshqa yangi tranzitlar yopiq. ADMINga WEB:22,80 va router:22 ruxsat etilgan. IPv6 tranziti uchun ruxsat qoidasi yo‘q. Qoidalar faol holatda; mashg‘ulotda reboot qilinmaydi. Karantin qo‘llangach base.nft ni qayta yuklamang: undagi flush ruleset karantin jadvalini ham o‘chiradi.

ADMINda kalit va dalil papkasini tayyorlash

```
# ADMIN oddiy foydalanuvchisida:
mkdir -p ~/.ssh ~/A17-IR-001
chmod 700 ~/.ssh ~/A17-IR-001
ssh-keygen -t ed25519 -f ~/.ssh/a17_ir -C 'A17-IR-admin'
ssh-copy-id -i ~/.ssh/a17_ir.pub labadmin@10.170.20.10
ssh -i ~/.ssh/a17_ir labadmin@10.170.20.10 'hostname; date -Is'
# WEB konsolida host fingerprintni oldindan ko'rish:
sudo ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
```

Birinchi SSH ulanishidan oldin WEB konsolidagi fingerprint bilan kelgan qiymatni solishtiring. ssh-copy-id labadmin parolini, keyingi SSH esa belgilangan kalit passphrase’ini so‘rashi mumkin. Dalil paketini olishda ham aynan shu ADMIN foydalanuvchisi va kaliti ishlatiladi. Yopiq kalit hisobotga qo‘shilmaydi.

4. WEB xizmati va insidentni modellashtirish

4.1. WEB root konsolida o‘quv xizmatini yaratish

Siyosat: / bosh sahifasi ochiq; /internal-demo/ esa HTTP orqali tarqatilmasligi kerak. Ataylab shu ikkinchi cheklov dastlab qo‘yilmaydi. log_format http kontekstidagi conf.d faylida belgilanadi; vaqt timezone bilan yoziladi. [3]

```
mkdir -p /srv/a17/www/internal-demo
printf 'A17 PUBLIC OK\n' > /srv/a17/www/index.html
printf 'A17-DEMO-NOT-REAL-DATA\n' > /srv/a17/www/internal-demo/record.txt
chmod -R a+rX /srv/a17
cat > /etc/nginx/conf.d/a17-log.conf <<'EOF'
log_format a17_ir '$time_iso8601|$remote_addr|$request_method|'
                  '$uri|$status|$body_bytes_sent|$http_user_agent';
EOF
cat > /etc/nginx/sites-available/a17 <<'EOF'
server {
  listen 80 default_server;
  server_name _;
  root /srv/a17/www;
  index index.html;
  access_log /var/log/nginx/a17-access.log a17_ir;
  error_log /var/log/nginx/a17-error.log info;
  location / { try_files $uri $uri/ =404; }
}
EOF
rm -f /etc/nginx/sites-enabled/default
ln -sfn /etc/nginx/sites-available/a17 /etc/nginx/sites-enabled/a17
nginx -t && systemctl reload nginx
curl --max-time 5 http://127.0.0.1/
ss -lntp
```

4.2. CLIENTda beshta boshqariladigan so‘rov

```
# CLIENT oddiy foydalanuvchisida:
mkdir -p ~/a17-test
for i in 1 2 3; do
  curl -sS --max-time 5 -A A17-Browser -o /dev/null \
    -w 'public HTTP=%{http_code}\n' http://10.170.20.10/
done
for i in 1 2; do
  curl -sS --max-time 5 -A A17-LabProbe \
    http://10.170.20.10/internal-demo/record.txt \
    -o ~/a17-test/demo-$i.txt -w 'internal HTTP=%{http_code}\n'
done
```

Kutiladi: 3 ta public/200 va 2 ta internal/200; ikkita faylda faqat sun’iy marker bo‘ladi. Besh so‘rovdan keyin CLIENTda trafik hosil qilishni to‘xtating. Bu parol buzish yoki zararli dastur ishlatish emas; ruxsat siyosati xatosini aniq va takrorlanuvchi tarzda ko‘rsatadi. Natijalarni haqiqiy kuzatuv sifatida qayd eting.

5. Aniqlash, triage va insident kartasi

5.1. WEB root konsolida shubhali murojaatni topish

```
CASE=/opt/a17/case-001
date -Is | tee "$CASE/detection-time.txt"
tail -n 20 /var/log/nginx/a17-access.log
awk -F'|' '$2=="10.170.30.10" && \
 $4=="/internal-demo/record.txt" && $5==200 {print}' \
 /var/log/nginx/a17-access.log | tee "$CASE/alert-lines.txt"
wc -l "$CASE/alert-lines.txt"
```

Yangi labda natija 2 satr bo‘lishi kutiladi. Bosh sahifa ichki index.htmlga yo‘naltirilgani sabab logda / o‘rniga /index.html ko‘rinishi mumkin. alert-lines.txt — tahlil uchun ajratilgan satrlar; to‘liq log dalili keyingi bo‘limda alohida saqlanadi.

5.2. Fakt va taxminni ajratish

- Tasdiqlangan fakt: WEB logida 10.170.30.10 manzilidan ichki URIga 200 javoblar qayd etildi; CLIENT sinovida sun’iy marker olindi.
- Asosli sabab: konfiguratsiyada /internal-demo/ uchun HTTP ruxsati cheklanmagan. Buni nginx -T va fayl joylashuvi bilan tekshirish kerak.
- Hozircha isbotlanmagan: insonning shaxsi, kompyuterga zararli dastur tushgani yoki ma’lumot Internetga tarqalgani. IP va User-Agent bunday xulosaga yetmaydi.
- Ko‘lam: hozircha bitta CLIENT, bitta WEB, ikkita kuzatilgan murojaat. Saqlangan log davridan tashqari hodisalar bo‘yicha “ma’lumot yetarli emas” deb yoziladi.

Karta maydoni	Talaba to‘ldiradi
Insident ID / sana	A17-IR-001 / _____
Aniqlash vaqti / operator	_____
Manba / nishon	10.170.30.10 → 10.170.20.10:80
Buzilgan siyosat	Ichki katalog HTTP orqali ochilmasligi kerak.
Ta’sir	Sun’iy ichki faylga ruxsatsiz murojaat; maxfiylik modeli.
Dastlabki daraja / asos	_____
Ko‘lam va noma’lumlar	_____
Cheklash qarori / mas’ul	_____

O‘quv ustuvorlik shkalasi: P1 — faol keng zarar yoki muhim xizmat uzilishi; P2 — tasdiqlangan, cheklangan siyosat buzilishi; P3 — tekshirish talab qiladigan shubhali hodisa; P4 — tasdiqlangan oddiy hodisa. Ushbu senariyga P2 mos keladi, ammo bu tashkilotning rasmiy tasnifi yoki NIST belgilagan P2 mezoni emas.

6. Dalillarni saqlash va hisobga olish

O‘quv senariyida so‘rovlar to‘xtatilgan, shuning uchun qisqa dalil olish cheklashdan oldin bajariladi. Haqiqiy davom etayotgan zarar bo‘lsa cheklash ustuvor bo‘lishi mumkin; qaror va sababi qayd etiladi. Faol tizimdan nusxa olish uning holatini o‘zgartiradi, buni yashirmang. [1, 4]

6.1. WEB root konsolida bir martalik boshlang‘ich nusxa

```
CASE=/opt/a17/case-001
mkdir -p "$CASE/raw" "$CASE/analysis"
chmod 700 "$CASE" "$CASE/raw"
date -Is > "$CASE/raw/collection-start.txt"
cp --preserve=timestamps /var/log/nginx/a17-access.log "$CASE/raw/"
cp --preserve=timestamps /var/log/nginx/a17-error.log "$CASE/raw/"
nginx -T > "$CASE/raw/nginx-T.txt" 2>&1
cp /etc/nginx/sites-available/a17 "$CASE/raw/site-before.conf"
cp /srv/a17/www/internal-demo/record.txt "$CASE/raw/record.txt"
ss -lntup > "$CASE/raw/listeners.txt"
ps auxww > "$CASE/raw/processes.txt"
ip -br addr > "$CASE/raw/ip.txt"
date -Is > "$CASE/raw/collection-end.txt"
cd "$CASE/raw"
sha256sum -- * > ../SHA256SUMS.txt
sha256sum -c ../SHA256SUMS.txt
chmod a-w -- *
cp a17-access.log ../analysis/access-working.log
```

raw fayllari birinchi yig‘ishdan keyin qayta yozilmaydi. Keyingi yig‘ish uchun raw-02 kabi yangi katalog yarating. SHA256SUMS.txtni raw tashqarisida saqlash manifestning o‘zini hashga qo‘shib yuborishni oldini oladi. Tahlil analysis nusxasida bajariladi; ishlayotgan nginx logi kesilmaydi va o‘chirilmaydi.

6.2. RTR-IRda tarmoq holatini saqlash

```
CASE=/opt/a17/case-001
date -Is > "$CASE/router-before.txt"
ip -4 route >> "$CASE/router-before.txt"
nft -a list ruleset >> "$CASE/router-before.txt"
ss -ntup >> "$CASE/router-before.txt"
sha256sum "$CASE/router-before.txt" > "$CASE/router-before.sha256"
```

Dalil ID	Manba / tarkib	Yig‘uvchi, vaqt, hash manzili
E01	WEB: to‘liq access/error log	_____
E02	WEB: config, fayl, faol holat	_____
E03	RTR: route, nft, socket	_____
E04	ADMIN: qabul qilingan nusxa	_____

Hash fayl o‘zgarganini aniqlashga yordam beradi; yig‘ishdan oldingi haqiqiylik yoki muallif shaxsini o‘zi isbotlamaydi. chmod ham rootga qarshi o‘zgarmas saqlash emas. Kim, qachon, qaysi manbadan olgani va nusxani kim qabul qilgani dalil harakati jurnalida yoziladi.

7. CLIENTni vaqtincha ajratish

7.1. RTR-IR root konsolida alohida karantin jadvali

Avval ip -br addr va dalil satrlaridan manbani qayta tekshiring. Karantin USERSdagi aynan 10.170.30.10 manzilining tarmoqlararo kiruvchi/chiquvchi trafikini to‘xtatadi. ADMIN va WEB xizmatlari saqlanadi. -10 priority asosiy forward chain’dagi 0 dan oldin ishlaydi, shuning uchun established oqimlar ham shu cheklovga tushadi. [2]

```
cat > /opt/a17/quarantine.nft <<'EOF'
table inet a17_ir {
  chain quarantine {
    type filter hook forward priority -10; policy accept;
    ip saddr 10.170.30.10 counter drop
    ip daddr 10.170.30.10 counter drop
  }
}
EOF
# Bu jadval hali mavjud bo'lmagan paytda bir marta:
nft -c -f /opt/a17/quarantine.nft && nft -f /opt/a17/quarantine.nft
date -Is | tee /opt/a17/case-001/containment-time.txt
nft -a list table inet a17_ir \
 | tee /opt/a17/case-001/quarantine-rules.txt
```

Bu cheklov CLIENT VM ichidagi jarayonni to‘xtatmaydi va shu USERS segmentidagi boshqa host bilan L2 aloqani qamramaydi. Ushbu labda USERSda bitta endpoint bor. IP almashsa manzilli karantin yetarli emas; bunday holat 4 soatlik kengaytirilgan qismda tahlil qilinadi.

7.2. Cheklash ta’sirini tekshirish

```
# CLIENTda: ulanish timeout, HTTP=000 kutiladi.
curl -sS --connect-timeout 3 --max-time 5 -o /dev/null \
 -w 'HTTP=%{http_code}\n' http://10.170.20.10/
# ADMINda: xizmat ishlashi saqlanadi, HTTP=200.
curl -sS --max-time 5 -o /dev/null -w 'HTTP=%{http_code}\n' \
 http://10.170.20.10/
ssh -i ~/.ssh/a17_ir labadmin@10.170.20.10 'hostname'
# RTR-IRda: manba drop qoidasidagi counter oshganini yozing.
nft list table inet a17_ir \
 | tee /opt/a17/case-001/quarantine-after-test.txt
```

curl chiqishidagi 000 HTTP javob kodi emas: HTTP javobi olinmaganini bildiradi. Timeout va router counter o‘sishini birga qayd eting. Faqat CLIENTdagi xato firewall ishlaganini to‘liq isbotlamaydi; WEB o‘chganida ham o‘xshash xato bo‘lishi mumkin. ADMIN/200 nazorat sinovi buni ajratadi.

Operativ xabar loyihasi

“A17-IR-001: ichki katalogga 2 ta ruxsatsiz o‘quv murojaati aniqlandi. Manba 10.170.30.10 vaqtincha ajratildi. Ochiq veb-xizmat ADMINdan ishlamoqda. Dastlabki log va konfiguratsiya nusxalari saqlandi. Sabab tekshirilmoqda; keyingi yangilanish vaqti: ____.” Bu matn hisobotda yoziladi, haqiqiy elektron pochta yoki messenjerga yuborilmaydi.

8. Vaqt chizig‘i va ko‘lamni tahlil qilish

8.1. WEBda tahlil nusxasidan CSV yaratish

Vaqt timezone bilan o‘qilib, UTCga keltiriladi. Skript faqat ushbu laboratoriyaning “|” bilan ajratilgan log formati va o‘quv User-Agent qiymatlari uchun yozilgan. Mos kelmagan satrlar tashlab yuborilmaydi: xato sifatida ko‘rsatiladi. Asl raw nusxaga yozilmaydi.

```
cat > /opt/a17/timeline.py <<'EOF'
import csv
from datetime import datetime, timezone
from pathlib import Path
base = Path('/opt/a17/case-001/analysis')
rows = []
for num, line in enumerate((base/'access-working.log').read_text().splitlines(), 1):
    fields = line.split('|', 6)
    if len(fields) != 7:
        raise ValueError(f'Log formati xato: satr {num}')
    stamp, ip, method, uri, status, size, agent = fields
    event_time = datetime.fromisoformat(stamp)
    if event_time.tzinfo is None:
        raise ValueError(f'Timezone yoq: satr {num}')
    rows.append([event_time.astimezone(timezone.utc).isoformat(),
                 ip, method, uri, int(status), int(size), agent, num])
rows.sort(key=lambda row: (row[0], row[7]))
with (base/'timeline.csv').open('w', newline='') as f:
    writer = csv.writer(f)
    writer.writerow(['utc', 'ip', 'method', 'uri', 'status', 'bytes', 'agent', 'line'])
    writer.writerows(rows)
hits = [r for r in rows if r[1] == '10.170.30.10'
        and r[3] == '/internal-demo/record.txt' and r[4] == 200]
print('Ichki URI uchun 200 javoblar:', len(hits))
print('Javob tanasi baytlari yigindisi:', sum(r[5] for r in hits))
EOF
python3 /opt/a17/timeline.py
cat /opt/a17/case-001/analysis/timeline.csv
```

Kutiladi: ushbu yangi senariyda 2 ta ichki URI/200 satri. body_bytes_sent yig‘indisi HTTP javob tanasi baytlari hisobidir; u noyob ma’lumot hajmi yoki Internetga sizib chiqish dalili emas. Takroriy so‘rov bitta faylni qayta sanaydi. [3]

8.2. Insident vaqt chizig‘iga boshqaruv amallarini qo‘shish

Hodisa	UTC vaqt	Dalil / izoh
Birinchi ichki murojaat	_____	timeline.csv va raw log satri
Aniqlash	_____	detection-time.txt
Cheklash	_____	containment-time.txt va nft
Tuzatish / tiklash	_____	Keyingi bo‘limdagi vaqtlar

TTD (aniqlash kechikishi) = aniqlash vaqti − birinchi kuzatilgan ichki murojaat; cheklash kechikishi = karantin vaqti − aniqlash vaqti. Bu bitta insident o‘lchovi; MTTD esa bir nechta insidentning TTD qiymatlari o‘rtachasidir. VM soatlari farq qilsa manfiy farqni yashirmang: tuzatish asosini yoki o‘lchov cheklovini yozing.

9. Sababni bartaraf etish va xizmatni tiklash

9.1. WEB root konsolida ichki katalogni HTTPdan yopish

Dalillar saqlanganini va raw hash tekshiruvi o‘tganini tasdiqlang. Hozir CLIENT karantinda. /internal-demo/ prefiksi barcha HTTP mijozlariga 403 qaytaradi; bosh sahifa ishlashda davom etadi. Ushbu aniq siyosat uchun location va return ishlatiladi. [5, 6]

```
cat > /etc/nginx/sites-available/a17 <<'EOF'
server {
  listen 80 default_server;
  server_name _;
  root /srv/a17/www;
  index index.html;
  access_log /var/log/nginx/a17-access.log a17_ir;
  error_log /var/log/nginx/a17-error.log info;
  location = /internal-demo { return 403; }
  location ^~ /internal-demo/ { return 403; }
  location / { try_files $uri $uri/ =404; }
}
EOF
nginx -t && systemctl reload nginx
date -Is > /opt/a17/case-001/fix-time.txt
cp /etc/nginx/sites-available/a17 /opt/a17/case-001/site-after.conf
# ADMINda, CLIENTni ochishdan AVVAL:
curl -sS --max-time 5 -o /dev/null -w 'public=%{http_code}\n' \
 http://10.170.20.10/
curl -sS --max-time 5 -o /dev/null -w 'internal=%{http_code}\n' \
 http://10.170.20.10/internal-demo/record.txt
```

Kutiladi: public=200 va internal=403. Sun’iy fayl o‘chirilmaydi, chunki sabab faylning mazmunida emas, uning noto‘g‘ri tarqatilishida. Ishlab chiqarishda ichki fayllarni web rootdan tashqarida saqlash ham alohida ko‘rib chiqiladi. Bu katalog barcha yo‘llar orqali mutlaq himoyalangan degan keng xulosa chiqarilmaydi; konfiguratsiyada alias va boshqa saytlar ham tekshirilishi kerak.

9.2. Karantinni olish va CLIENTdan qayta sinash

```
# RTR-IR root konsolida, ADMINning 200/403 sinovlari o'tgach:
nft delete table inet a17_ir
date -Is > /opt/a17/case-001/release-time.txt
nft list ruleset > /opt/a17/case-001/rules-after-release.txt
# CLIENTda:
curl -sS --max-time 5 -o /dev/null -w 'public=%{http_code}\n' \
 http://10.170.20.10/
curl -sS --max-time 5 -o /dev/null -w 'internal=%{http_code}\n' \
 http://10.170.20.10/internal-demo/record.txt
nc -vz -w 3 10.170.20.10 22
```

Kutiladi: CLIENTdan ham 200/403; WEB:22 avvalgidek timeout. Faqat a17_ir jadvali olib tashlanadi, a17_base saqlanadi. Tuzatish ishlamasa CLIENT karantinini saqlang, sintaksis va aktiv konfiguratsiyani tekshiring; xizmatni ochish maqsadida barcha firewall qoidalarini o‘chirmang.

10. Dalil paketini topshirish va yaxlitligini tekshirish

10.1. WEBda keyingi holatni alohida saqlash

```
CASE=/opt/a17/case-001
mkdir -p "$CASE/post"
cp /var/log/nginx/a17-access.log "$CASE/post/access-after.log"
cp /var/log/nginx/a17-error.log "$CASE/post/error-after.log"
nginx -T > "$CASE/post/nginx-after.txt" 2>&1
date -Is > "$CASE/post/recovery-time.txt"
cd "$CASE/raw"
sha256sum -c ../SHA256SUMS.txt
# labadmin faqat o'qiy oladigan eksport katalogi:
install -d -o root -g labadmin -m 750 /opt/a17/export
tar -czf /opt/a17/export/A17-IR-001-web.tar.gz -C /opt/a17 case-001
cd /opt/a17/export
sha256sum A17-IR-001-web.tar.gz > A17-IR-001-web.sha256
chown root:labadmin A17-IR-001-web.*
chmod 640 A17-IR-001-web.*
cat A17-IR-001-web.sha256
```

Standart Ubuntu o‘rnatilishida labadminning o‘z nomli guruhi mavjud bo‘ladi; id labadmin bilan tekshiring. Agar guruh nomi boshqacha bo‘lsa, install/chown buyruqlarida haqiqiy asosiy guruh nomini yozing. Arxivga /etc/ssh yoki yopiq kalitlar qo‘shilmaydi.

10.2. ADMIN oddiy foydalanuvchisida qabul qilish

```
cd ~/A17-IR-001
scp -i ~/.ssh/a17_ir \
 labadmin@10.170.20.10:/opt/a17/export/A17-IR-001-web.tar.gz .
scp -i ~/.ssh/a17_ir \
 labadmin@10.170.20.10:/opt/a17/export/A17-IR-001-web.sha256 .
sha256sum -c A17-IR-001-web.sha256
mkdir -p received
tar -xzf A17-IR-001-web.tar.gz -C received
cd received/case-001/raw
sha256sum -c ../SHA256SUMS.txt
```

Tashqi arxiv hashini WEB konsolida qayd qilingan qiymat bilan solishtiring; arxiv va hashni bir kanaldan olish manba haqiqiyligini mustaqil tasdiqlamaydi. Ikki hash tekshiruvi ham OK bo‘lsin. RTR-IR dalillarini ham hypervisor shared folder orqali alohida nusxalang, routerdagi hash bilan solishtiring va E03 sifatida topshiring.

Dalil harakati	Vaqt / tomonlar	Nazorat natijasi
WEB → ADMIN	_____ / _____	Arxiv SHA256: _____
ADMINda ochilgan raw	_____ / _____	Ichki manifest: _____
RTR → hisobot nusxasi	_____ / _____	Fayl SHA256: _____

O‘quv dalil paketi to‘liq forensik disk/RAM obrazi emas. Arxivdagi process/socket holati qisqa kuzatuvdir; muvaffaqiyatli hash tekshiruvi mavjud dalillarning ko‘lamini kengaytirmaydi. Nusxa olish ishlari va operator aralashuvlari hisobotda qayd etiladi. [4]

11. Qabul sinovlari va nosozliklarni tahlil qilish

ID	Sinov / kutiladigan natija	Natija, vaqt, dalil
T1	Dastlab CLIENT: public 200, internal 200	_____
T2	Alert filtrida 2 ta tegishli log satri	_____
T3	Boshlang‘ich raw manifestida barcha fayllar OK	_____
T4	Karantinda CLIENT: timeout/000 va drop counter	_____
T5	Karantinda ADMIN: public 200, SSH ishlaydi	_____
T6	Timeline: 2 ta ichki 200, asl log satr raqamlari	_____
T7	Karantin paytida tuzatish: ADMIN 200/403	_____
T8	Karantindan so‘ng CLIENT 200/403, SSH yopiq	_____
T9	ADMINda arxiv va raw hash tekshiruvlari OK	_____
T10	Karta, vaqtlar, sabab va qoldiq xavflar yozilgan	_____

Nosozlikni dalil bilan farqlash

Belgi	Tekshiriladigan sabab
CLIENT dastlab ham 000	WEB nginx, gateway, router forwarding va base qoidasini tekshirish.
Alert 0 satr	IP/URI, 200 status, faol sayt, log nomi va so‘rov qaydini tekshirish.
Alert 2 dan ko‘p	Eski lab logi yoki qayta so‘rov; satrlarni o‘chirmasdan davrni aniqlash.
Karantinda CLIENT hali 200	To‘g‘ri source IP, trafikning routerdan o‘tishi va priority -10.
ADMIN ham ishlamaydi	Nishon WEB manzili karantinga tushmaganmi; base va nginx holati.
403 o‘rniga 200 qaytdi	nginx -t, nginx -T, faol symlink va location mosligini tekshirish.
scp Permission denied	Kalit, labadmin guruhi, export 750 va fayllar 640.
Hash mos emas	Noto‘g‘ri nusxa yoki o‘zgarish; dalilni almashtirmasdan yangi nusxa olish.

Sinov bajarilmasa “bajarilmadi” deb yozing. Kutilgan qiymatlarni haqiqiy natija o‘rniga kiritmang. Log, konfiguratsiya, HTTP natija va firewall counter bir-birini to‘ldiradi; birining yo‘qligi xulosa ishonchliligini pasaytirishi mumkin.

12. Mustaqil topshiriqlar va 4 soatlik ish rejasi

Asosiy topshiriqlar — taxminan 80 daqiqa

1. To‘rt VM va uch segmentni tayyorlang; IP/gateway jadvalini tuzing va boshqaruv yo‘lini tekshiring.
2. O‘quv HTTP hodisasini hosil qiling, uni toping va A17-IR-001 kartasida fakt hamda taxminni ajrating.
3. Log va konfiguratsiya nusxalarini saqlang; dalil manifestini yaratib tekshiring.
4. CLIENTni ajrating; uning bloklanganini va ADMIN xizmati saqlanganini isbotlang.
5. Vaqt chizig‘ini yarating, sababni tuzating, karantinni olib 200/403 natijalarini tasdiqlang.
6. Dalil paketini ADMINga olib hashlarini tekshiring; T1–T10 va qisqa yakuniy hisobotni to‘ldiring.

Asosiy bosqich	Daqiqa
Muhit, IP, firewall va WEB	20
Hodisa, aniqlash va karta	10
Dalillar va karantin	15
Timeline, tuzatish va tiklash	20
Paket, qabul sinovlari va hisobot	15
Jami	80

Chuqurlashtirilgan qism — yana taxminan 80 daqiqa

Topshiriq	Vaqt	Tekshiriladigan natija
Ko‘lam tahlili: barcha IP/URI/statuslarni sanash	20	Qaysi manbalar va yo‘llar tekshirildi, qaysi davr noma’lum.
Hash xatosi: faqat analysis nusxasini o‘zgartirish	15	Mos kelmaslik ko‘rsatiladi; raw manifesti OK qoladi.
Karantin cheklovi: IP almashishi va L2 holati	15	Jadvalda joriy himoya chegarasi va port/VM orqali ajratish rejasi.
Yakuniy xabar, sabablar va profilaktika rejasi	15	Har chora uchun mas’ul, muddat, qayta tekshiruv.
O‘zaro audit va og‘zaki himoya	15	Sherik T1–T10 dalillarini tekshiradi; e’tirozlar yoziladi.

Hash tajribasi uchun analysis katalogiga raw/record.txt nusxasini oling, nusxaning hashini yozing, unga DEMO-CHANGE satrini qo‘shib qayta hisoblang. Asl raw/record.txtga tegmang. Karantin cheklovi topshirig‘i jadval va qaror tahlili bilan bajariladi; yangi IPdan cheklovni aylanib o‘tish majburiy emas.

A17 dasturda 4 akademik soat. Bu variant 80+80 daqiqalik ikki amaliy blokka mos tuzilgan; tanaffus va OTMdagi akademik soat davomiyligi dars jadvaliga muvofiq belgilanadi. Obraz va paketlarni yuklash ushbu vaqtga kiritilmaydi.

13. Hisobot, baholash, himoya va manbalar

Topshiriladigan hisobot

Titul: fan, A17, 1-variant, 5-semestr, F.I.Sh., guruh, sana. Mazmun: maqsad va topologiya; insident kartasi; fakt/taxmin/ko‘lam; E01–E04 reyestri; UTC vaqt chizig‘i; qarorlar jurnali; T1–T10; ildiz sabab; profilaktika va yakunlash qarori. “Yopildi” holati tiklash mezonlari dalillar bilan tasdiqlangach qo‘yiladi.

Kamida 6 skrinshot: (1) IP/route; (2) CLIENT natijasi va alert satrlari; (3) raw hash OK; (4) karantin counter va ADMIN/200; (5) timeline hamda tiklashdagi 200/403; (6) ADMINda paket va raw hash OK. Matnli dalillar ham topshiriladi. Parol, yopiq kalit yoki haqiqiy shaxsiy ma’lumot qo‘shilmaydi.

Baholash mezoni	Ball
Topologiya, IP va boshlang‘ich xizmat	1.0
Aniqlash, triage, karta va ko‘lam	1.5
Dalil nusxasi, hash va dalil harakati qaydi	2.0
Karantin va xizmat uzluksizligini tekshirish	1.5
Sababni tuzatish va tiklash sinovlari	2.0
Timeline, hisobot va og‘zaki himoya	2.0

Himoya savollari

1. Hodisa qaysi dalil asosida insident deb baholandi?
2. IP va User-Agent inson shaxsini nega tasdiqlamaydi?
3. Qaysi vaziyatda cheklash dalil olishdan oldin bajariladi?
4. SHA256 va dalil harakati jurnali turli qanday vazifani bajaradi?
5. Karantin nega priority -10 da joylashtirildi?
6. HTTP 000 va HTTP 403 o‘rtasida qanday farq bor?
7. Logdagi baytlar yig‘indisi ma’lumot sizib chiqishini isbotlaydimi?
8. Tiklashdan keyin qaysi qoldiq xavflar saqlanadi?

Rasmiy manbalar

[1] NIST SP 800-61 Rev. 3 (2025). https://csrc.nist.gov/pubs/sp/800/61/r3/final

[2] Netfilter — nft manual. https://www.netfilter.org/projects/nftables/manpage.html

[3] nginx — HTTP log module. https://nginx.org/en/docs/http/ngx_http_log_module.html

[4] NIST SP 800-86 — Integrating Forensic Techniques into Incident Response. https://csrc.nist.gov/pubs/sp/800/86/final

[5] nginx — HTTP core module (location). https://nginx.org/en/docs/http/ngx_http_core_module.html

[6] nginx — HTTP rewrite module (return). https://nginx.org/en/docs/http/ngx_http_rewrite_module.html

Kutiladigan natijalar Ubuntu Server 24.04 LTS asosidagi o‘quv senariysi uchun berilgan. O‘qituvchi tanlangan VM obrazlarida to‘liq amaliy sinovni oldindan bajaradi; talaba jadvalga o‘zining haqiqiy o‘lchovlarini kiritadi.